



Jornada 4 Ingeniería Social

"Si es humano, es hackeable"



Fases de un Ethical Hacking

Reconocimiento

Rastreo

Toma de Acceso

Mantenimiento del Acceso

Limpieza

¿Qué es la IS?

La ingeniería consiste en la manipulación de las personas para que voluntariamente realicen actos que normalmente no harían.

El objetivo es manipular, engañar o persuadir a la gente para que revele contraseñas u otra información que comprometa la seguridad del sistema objetivo.

El principio que sustenta la ingeniería social es el que en cualquier sistema "los usuarios son el eslabón débil"

HISTORIA

¿¿Desde siempre ??

En el sector tic el creador
fue Kevin Mitnick



Kevin Mitnick siempre decía:

- A todos nos gusta que nos alaben.
- El primer movimiento es siempre de confianza hacia el otro.
- No nos gusta decir “No”, solo decir “Sí”.
- Todos queremos ayudar

Objetivos: ¿Qué quieren hacer?

- Los objetivos básicos de la Ingeniería Social es ganar acceso no autorizado a los sistemas, redes o a la información para:
 - Cometer fraude
 - Entrometerse en las Redes
 - Espionaje industrial
 - Robo de identidad
 - Irrumpir en los Sistemas o Redes

Objetivos: ¿A quien van dirigidos?

- Las victimas mas comunes suelen ser:
 - Empresas Telefónicas
 - Servicios Helpdesk
 - Corporaciones renombradas
 - Instituciones Financieras
 - Hospitales

Perfil de un buen IS

- PROFESIONALES CON UN PERFIL TIC CON CONOCIMIENTOS EN EL ÁREA
- CONOCIMIENTOS Y EXPERIENCIA EMPRESARIAL
- HABILIDADES SOCIALES (ELOCUENCIA, EMPATÍA) .. A UN NIVEL ALTO
- EXPERTO EN SEGURIDAD DE LA INFORMACION
- IMAGINACION

TIPOS DE INGENIEROS SOCIALES

- INSIDER
- CIBERDELINCUENTES
- HACKERS ETICOS
- ESPIAS
- OTROS

INSIDER



ATACANTE QUE SUELE TENER CIERTOS PRIVILEGIOS O NIVEL DE CONFIANZA EN LA ORGANIZACIÓN

SON DIFÍCILES DE DETECTAR POR ELLO Y LOS QUE MAS DAÑO PUEDEN LLEGAR A HACER A VECES

LAS MOTIVACION PUEDE SER VARIADA, AUNQUE LA RAZÓN PRINCIPAL SUELE SER VENGANZA

CIBERDELICUENTES



PERFIL MÁS TÉCNICO CON TÉCNICAS DE HACKING

USA LA INGENIERÍA SOCIAL A LA HORA DE RECOPILAR
INFORMACIÓN

EL MOTIVO PRINCIPAL SIEMPRE ES ECONÓMICO

HACKERS ETICOS



PENTESTERS AUTORIZADOS POR LA ORGANIZACIÓN
OBJETIVO QUE PUEDE USAR LAS TÉCNICAS DE IS PARA
AUDITAR LA SEGURIDAD

LA PRINCIPAL DIFERENCIA DEL RESTO ES QUE TODO ESTÁ
PERMITIDO MEDIANTE CONTRATO

NO TIENE NINGUNA MALA INTENCIÓN

ESPÍAS



PERSONAL INVOLUCRADO EN TAREAS DE ESPIONAJE
PRIVADO O GUBERNAMENTAL

SUELE SER PARA RESOLVER UNA MISIÓN

SUPLANTAR IDENTIDADES ES UNA DE LAS TÉCNICAS
DE IS MAS UTILIZADAS POR ESTOS

RECOPILACION DE INFORMACIÓN

- FOCA
- CREEPY
- THEHARDVESTER
- MALTEGO
- DMITRY

Perfil de las victimas

- USUARIOS CONFIADOS
- USUARIOS DESCONFIADOS
QUE NO RAZONAN
- USUARIOS DESCONFIADOS
QUE RAZONAN



CASO

UNA TORTUGA SE COME AL ELEFANTE de 3 cabezas EN
EL ZOO DE NUEVA YORK

PULSA EN EL **BOTÓN** PARA VER EL VIDEO COMPLETO



REACCIONES DE LAS VICTIMAS SEGÚN EL PERFIL

SOLUCION

Usuario confiado --> flipa!! Seguro que mañana es trending topic!

EL DESCONFIADO QUE NO RAZONA PIENSA SEGURO QUE ES UN TIMO Y ME QUIEREN VENDER ALGO PERO ACABA DÁNDOLE AL ENLACE

EL DESCONFIADO QUE RAZONA NO LE DA YA QUE ES IMPOSIBLE UN ELEFANTE CON 3 CABEZAS Y QUE SE LO COMA UNA TORTUGA, SERÁ PUBLICIDAD O UN VIRUS

ATAQUES COMUNES

Ataques Locales

PIGGYBACKING Y TAILGATING

Este ataque se basa en seguir a un usuario autorizado hasta una zona donde nosotros no estemos autorizados y aprovecharnos de los privilegios de este.

En una palabra : COLARSE



ATAQUES COMUNES

Ataques Locales

DUMPSTER DIVING

Consiste en buscar en la basura o sitios donde se acumulan desechos de información que podría ser utilizada por el ingeniero social

Se puede encontrar: memorias usb, discos duros, contraseñas, facturas, nominas, información de empleados o de la propia empresa muy comprometida



CASO BBVA

[Portada](#) > [Castilla y León](#)

VALLADOLID | 'EL MUNDO' LO DESVELÓ EN FEBRERO DE 2006

Multa de 60.000 euros a BBVA por el abandono de datos confidenciales en un descampado

- La Agencia de Protección de Datos sanciona la "conducta negligente" del banco
- La entidad alega que la responsabilidad corresponde a la empresa de limpieza

Actualizado sábado 19/04/2008 08:49 (CET)



ESTHER NEILA

VALLADOLID.- BBVA deberá hacer frente a una multa de 60.101,21 euros por el abandono de cientos de documentos confidenciales en un descampado anexo al polígono industrial de San Cristóbal, hecho que fue revelado por EL MUNDO en su edición del 6 de febrero de 2006.

Más de dos años después, la **Agencia de Protección de Datos** sanciona al banco por una "clara conducta negligente" en su obligación de custodiar información privada de los clientes, para



▲ Los documentos aparecieron esparcidos entre

ATAQUES COMUNES

Ataques Locales

Eavesdropping

Se trata de escuchar una conversación privada para recopilar información.

Suele emplearse también en escuchar audios de whatsapp, leer conversaciones de correo o escuchar conversaciones por el móvil, aunque en este caso nos referimos a estar presente.



ATAQUES COMUNES

Ataques Locales

Shoulder surfing

Técnica de observación directa y de las mas antiguas.

El atacante trata de mirar disimuladamente para averiguar por ejemplo una contraseña.



ATAQUES COMUNES

Ataques Locales

Office snooping

Se trata de aprovechar la ausencia de un compañero para ocupar su posición mientras este ausente para husmear.



ATAQUES COMUNES

Ataques Locales

BAITING

El atacante intentara propagar un malware o troyano aprovechando la curiosidad de las victimas para poner un cebo.



ATAQUES COMUNES

Ataques Locales

BRIBING

Sobornar al personal o una persona cercana del objetivo con dinero o algo suyo a cambio de información confidencial



ATAQUES COMUNES

Ataques Remotos

Phising

Esta técnica busca “pescar” víctimas. Para ello se utiliza el envío de correos electrónicos conteniendo adjuntos con malware o links a páginas falsas (home banking, tarjeta de crédito, etc.) con el objetivo de tomar control del equipo de la víctima o buscando establecer una relación con la mismas (jugando con sus sentimientos).



ATAQUES COMUNES

Ataques Remotos

Redes Sociales

Esta técnica tiene dos grandes objetivos, obtener información de la víctima por una lado y generar una relación con la misma por otro.

Existen muchas personas “fanáticas” de las redes sociales, las cuales dan a conocer su vida minuto a minuto, en este caso este tipo de persona es “Oro en Polvo” para los atacantes ya que si la misma es el objetivo se podrá obtener muchísima información que será de gran utilidad.

Hoy en día no solo se utiliza informáticamente hablando, si no que, los ladrones también se aprovechan mucho de esta técnica para saber si las victimas están de vacaciones.



ATAQUES COMUNES

Ataques Remotos

Telefónicos

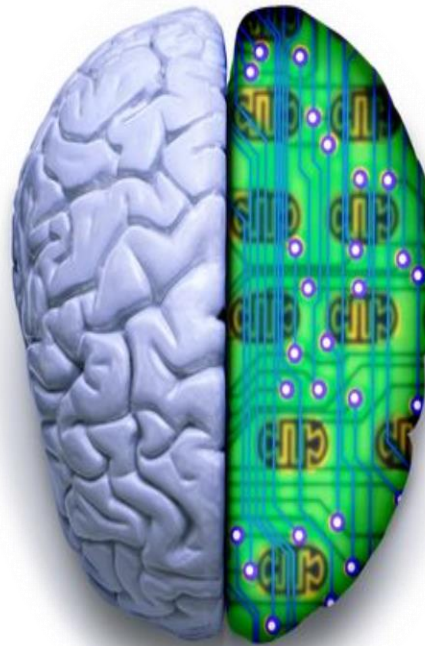
Este tipo de ataque es muy efectivo y utilizado en conjunto con las técnicas de “Pretexting” e “Impersonate” que vimos al principio, siendo mucho más cómodo y seguro para el Ingeniero Social usar un teléfono a contraparte de estar en forma presencial delante de su víctima.



ATAQUES COMUNES

Ingeniería inversa

El atacante espera que la victima vaya a el



TÉCNICAS DE SUPLANTACIÓN

- Física
- Lógica
- digital

FISICA



LÓGICA

ES AQUELLA QUE UTILIZA CUALQUIER
MEDIO TECNOLÓGICO.



LÓGICA

PHISHING



1. Phishing Bancario

Duración: 5 horas

Medio: Correo electrónico

35

tarjetas de crédito robadas

33

personas que ingresaron a la página web falsa por hora



1 de cada 5 personas entregaron sus datos financieros

Fuente: <http://eset.la/CMUJqzy>



2. Robo de contraseñas de Hotmail

Duración: 6 días

Medio: Infección de malware

+27.000

ingresos de datos por parte de los usuarios

8.200

credenciales robadas

Fuente: <http://eset.la/nDNWtH>



3. En Twitter

Medio: Redes Sociales

31.000

cuentas de Twitter robadas



.gov .edu .org dominios de algunas cuentas robadas

Fuente: <http://eset.la/CMUJt1m>

LÓGICA PHISHING

¿CUÁNTO PODRÍA LLEGAR A GANAR UN ATACANTE?



Se tomó como referencia un caso en el que un atacante envió 1 millón de correos, en donde un bajo porcentaje de personas hicieron clic (0,5%) y sólo una porción de esas personas (20%) ingresaron sus datos. En ese tipo de ataque simple, la ganancia podría ser de 10.000 dólares.

DIGITAL



Juan Carlos I

@ReyJuanCarlosI

Mi hiena de augurio y satisfacción poder acecarme a la ciudadanía. Roántico, soñador, campechano, friki de la series... (Este perfil es una PARODIA)




Tweets Favoritos Siguiendo Seguidores Listas



ReyJuanCarlosI Juan Carlos I

A mí no se me caen los anillos si hay que echar una mano en casa.

6 jun



ReyJuanCarlosI Juan Carlos I

¿Os podéis creer que aún no sé haceme el nudo de la cobata?

6 jun



ReyJuanCarlosI Juan Carlos I

Buenas noches y próspero año nuevo.

5 jun



ReyJuanCarlosI Juan Carlos I

Nunca dejéis de peseguir vuetros sueños.

5 jun



ReyJuanCarlosI Juan Carlos I

Dratini está evolucionando.



Acerca de @ReyJuanCarlosI

262 Tweets

5 Siguiendo

6.038 Seguidores

131 Listas

Tú y @ReyJuanCarlosI

Sigues una cuenta que sigue a @ReyJuanCarlosI · [ver](#)



Similar a @ReyJuanCarlosI · [ver todos](#)



HRHDoE Phillip Windsor · [Seguir](#)

Husband to QEII HRH Prince Order of the Garter, fr.



anaSM Ana · [Seguir](#)

Soy única... exactamente igual que todos los demás.



fernandopolanco Fernando Polanco · [Seguir](#)

Ser de bajos fondos y años flequillos.

Siguiendo · [ver todos](#)



[Sobre nosotros](#)
[Ayuda](#)
[Blog](#)
[Móvil](#)
[Estado](#)
[Trabajos](#)

[Condiciones](#)
[Privacidad](#)
[Atajos](#)
[Publicidad](#)
[Negocios](#)
[Media](#)

[Desarrolladores](#)
[Recursos](#)
[© 2011 Twitter](#)

SET



```
[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReLlK) [---]
[---] Version: 6.2 [---]
[---] Codename: 'Recharge' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
```

Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

Join us on irc.freenode.net in channel #setoolkit

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: <https://www.trustedsec.com>

“the quieter you become, the more you are able to hear”

PHISHING

Taller 1

BackDoor Usb

Taller 2

USB SPY

Taller 3

USB STEAL

Taller 4

IMAGEN INFECTADA

Taller 5

MEDIDAS

- VIGILAR EL CLIMA LABORAL Y RRHH
- REALIZACION DE PENTESTING SIN AVISAR
- TENER UN PLAN DE RESPUESTA EN EL CASO DE QUE OCURRA UN ATAQUE
- USAR EL SENTIDO COMUN
- IMPLEMENTAR MEDIDAS FISICAS
- DECIR NO A VECES ES LO MEJOR

MEDIDAS

- ESTABLECER UNAS POLITICAS DE SEGURIDAD
- ACCIONES DE FORMACION Y EDUCACION PARA USUARIOS Y PROFESIONALES
- CONTAR CON MEDIDAS QUE DESTRUYAN LA INFORMACION DE FORMA SEGURA
- DEFINIR LA INFORMACION EN DIFERENTES NIVELES: OUBLICA, PRIVADA, RESTRINGIDA, SECRETA
- PROTECCION ANTES SHOULDER SURFING